

南开大学

汇编语言与逆向技术课程实验报告

Lab10: CTF (Capture The Flag)



学院：密码与网络空间安全学院

专业：信息安全

学号：2412266

姓名：杨滢

班级：信息安全

目录

1	实验时间	2
2	实验目的	2
3	实验环境	2
4	实验原理	2
4.1	利用 Binary Ninja 修改静态资源	2
4.2	利用 Binary Ninja 修改反汇编指令	2
5	game.exe 的主要逻辑结构和重要数据	2
5.1	逻辑结构	2
5.2	重要数据	3
6	修改过程	4
6.1	思路一：修改静态资源	4
6.1.1	最高血量 HP	4
6.1.2	子弹数量	5
6.2	思路二：修改反汇编指令	6
7	实验结果	8
8	其他可能实现方式	8
9	实验总结	8

1 实验时间

第 17 周星期一 9-10 节

2 实验目的

1. 熟悉静态反汇编工具 Binary Ninja;
2. 掌握对二进制代码内部逻辑关系的分析;
3. 掌握对二进制代码的修改和保存。

3 实验环境

Binary Ninja

4 实验原理

4.1 利用 Binary Ninja 修改静态资源

1. 在反汇编代码的线性试图中找到需要修改的静态资源。右键点击数值选择 Type 可以转换数据的解析类型。
2. 在十六进制视图中 (Hex View) 找到指定区域, 点击右下角解锁按钮后, 对资源进行修改。
3. 点击 File → Save As..., 选择 Save file contents only, 点击 Save 按钮完成修改。注意留存备份, 避免覆盖原始程序。

4.2 利用 Binary Ninja 修改反汇编指令

1. 在反汇编代码中的线性视图找到需要修改的反汇编指令。
2. 右键点击指令, 选择 Patch, 可以将跳转方式反转, 或修改成无条件跳转、不跳转等。如需修改整条反汇编指令, 可以选择 Patch→ Edit Current Line。
3. 点击 File → Save As..., 选择 Save file contents only, 点击 Save 按钮完成修改。注意留存备份, 避免覆盖原始程序。

5 game.exe 的主要逻辑结构和重要数据

5.1 逻辑结构

game.exe 是一个闯关游戏。从 mainloop() 和中可以看出, 这个游戏共有 4 关, 每通过一关会显示进程 Z KEY DECRYPTING PROGRESS, 并调用一次 writekey。

通过进行游戏, 可以发现通关要求我们每关解决一定数量的 monster。解决 monster 需要通过使用武器造成伤害, 每次使用不同的武器会造成不同程度的子弹损耗。同时, 在消灭 monster 后下程实践可能得到一定的子弹增加或血量恢复。

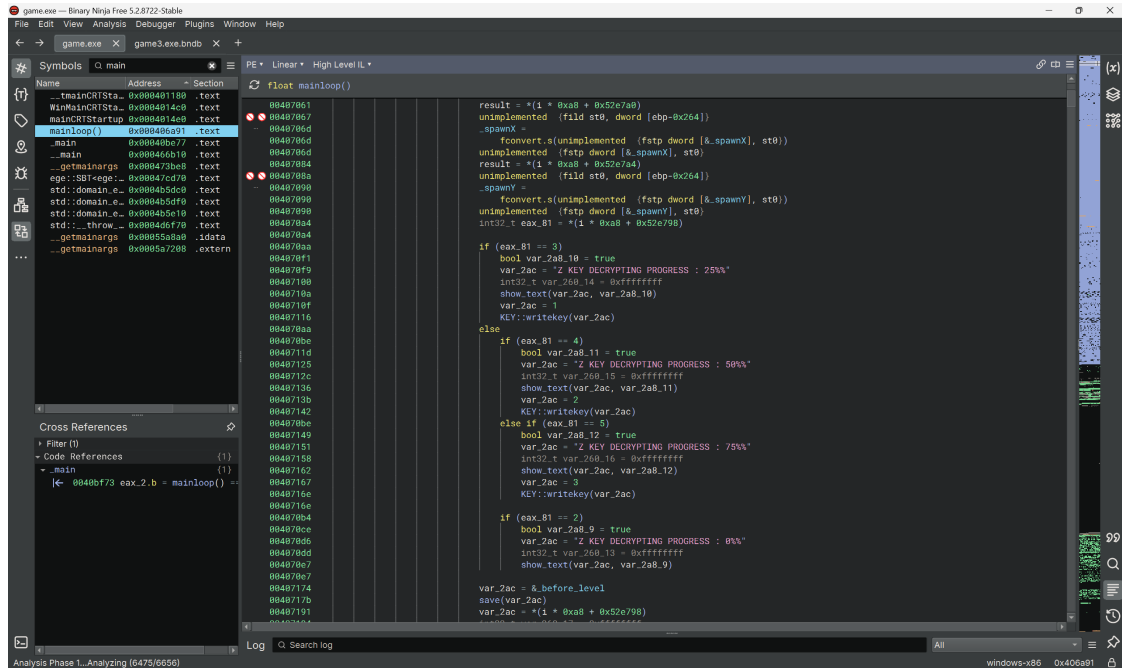


图 5.1: mainloop

实现全部通关后即可得到 flag。

5.2 重要数据

在.data 里面，可以看到游戏的一些参数设置：

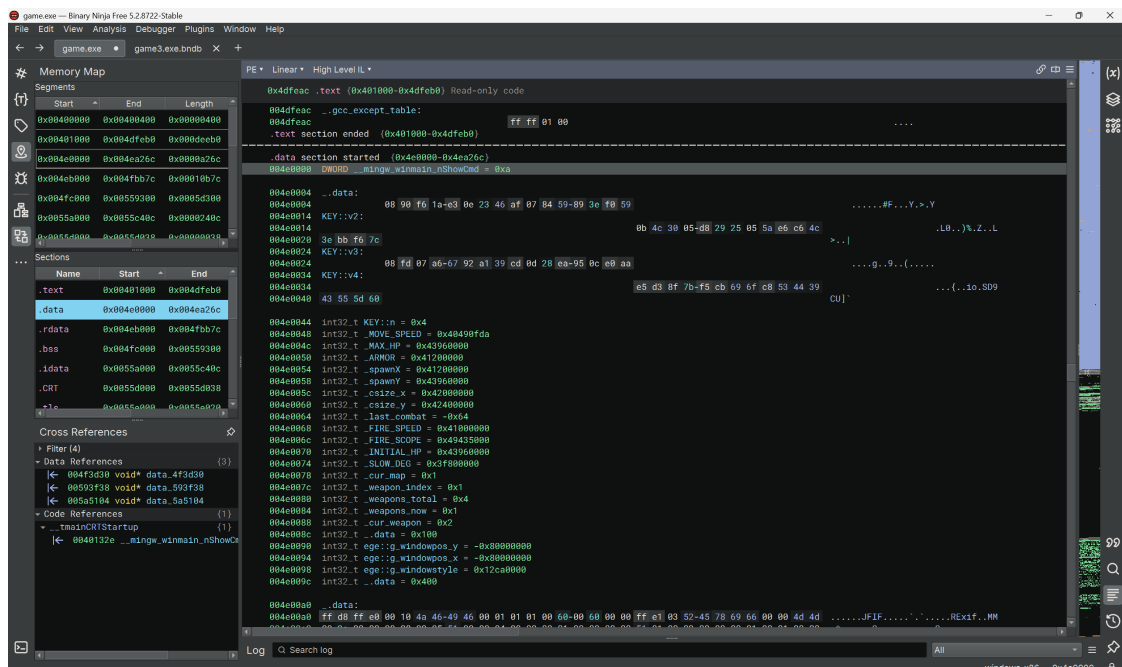


图 5.2: .data

右键 type 可以转换类型更加直观查看，得到 game.exe 的重要数据如下：

```

1 004e0048 float _MOVE_SPEED = 3.1415925 // 移动速度
2 004e004c float _MAX_HP = 300 // 最大生命值
3 004e0050 float _ARMOR = 10 // 护甲值
4 004e0054 float _spawnX = 10 // 出生点的X坐标
5 004e0058 float _spawnY = 300 // 出生点的Y坐标
6 004e005c float _csize_x = 32 // 角色尺寸的宽度
7 004e0060 float _csize_y = 48 // 角色尺寸的高度
8 004e0068 float _FIRE_SPEED = 8 // 攻击速度
9 004e006c float _FIRE_SCOPE = 800000 // 攻击范围
10 004e0070 float _INITIAL_HP = 300 // 初始生命值

```

跳转到 `data_init()`，可以发现对于子弹 `bullet` 和武器 `weapon` 的一些初始设置。

再通过对 `monster` 的搜索，可以定位 `monster::die()`，找到对于每种 `monster`，消灭它之后会得到什么奖励：

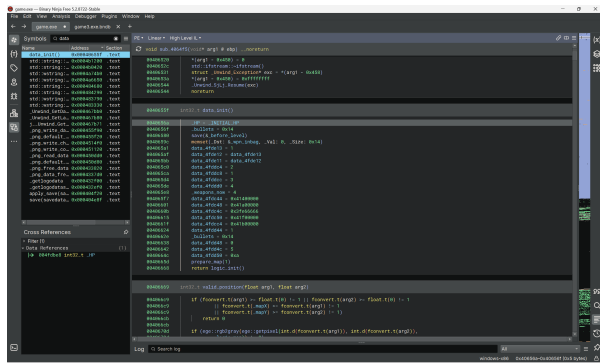


图 5.3: data_init()

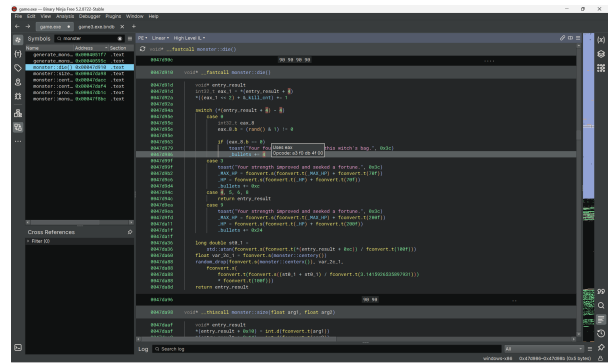


图 5.4: monster::die()

结合两者可以得到关于 `bullet` 的重要数据。

6 修改过程

6.1 思路一：修改静态资源

由于通关需要解决一定数量的 `monster`。解决 `monster` 需要通过使用武器造成伤害，每次使用不同的武器会造成不同程度的子弹损耗，并且在消灭 `monster` 后下程实践可能得到一定的子弹增加或血量恢复。我们可以分析得知通关拿到 `flag` 的两个重要数值：

1. 最高血量 HP
2. 子弹数目 bullet

6.1.1 最高血量 HP

首先考虑修改血量，尝试将血量改为 `inf` 无限大 `0x7f800000`。

切换到 Hex editor 打开右下角锁后修改图中标注区域数值（图中已改完）

PE ▾	Hex ▾	
004dfe20	ff 00 09 01 02 00 03 7f-00 00 7d 00 00 00 00 00-ff ff 01 02 00 00	
004dfe40	01 02 00 00 ff ff 01 02-00 00 ff ff 01 02 00 00-ff ff 01 02 00 00	
004dfe60	00 00 ff ff 01 02 00 00-ff ff 01 02 00 00 ff ff-01 02 00 00 ff 00	
004dfe80	00 00 00 00 ff 00 09 01-02 00 01 7f 00 00 00 00-00 00 00 00 ff 00	
004dfea0	7d 00 00 00 00 00 00 00-dc 7c 4f 00 ff ff 01 00	
004e0000	0a 00 00 00 08 90 f6 1a-e3 0e 23 46 af 07 84 59-89 3e f0 59 0b 4c 3	
004e0020	3e bb f6 7c 08 fd 07 a6-67 92 a1 39 cd 0d 28 ea-95 0c e0 aa e5 d3 5	
004e0040	43 55 5d 60 04 00 00 00-da 0f 49 40 00 00 80 7f-00 00 20 41 00 00 2	
004e0060	00 00 40 42 9c ff ff ff-00 00 00 41 00 50 43 49-00 00 80 7f 00 00 3	
004e0080	04 00 00 00 04 00 00 00-02 00 00 00 00 01 00 00-00 00 00 80 00 00 0	
004e00a0	ff d8 ff e0 00 10 4a 46-49 46 00 01 01 01 00 60-00 60 00 00 ff e1 0	
004e00c0	00 2a 00 00 00 08 00 05-51 00 00 04 00 00 00 01-00 00 00 00 51 01 0	
004e00e0	51 02 00 01 00 00 03 00-00 00 00 4a 51 03 00 01-00 00 00 01 ff 00 0	
004e0100	ff 00 00 00 00 00 00 00-18 88 d3 c8 d9 d6 fd fd-fd ac bb ba f5 f5 t	
004e0120	ce de db b0 b1 b1 f1 f1-f1 94 a3 a3 9c ab ab 16-78 b9 ed ed ed 49 9	
004e0140	d0 8c 9a 9a 84 92 92 c0-d1 cf b8 b9 b9 ba d1 d4-e5 e5 e5 be be be 0	
004e0160	79 ae cd dc da af b2 b2-de de de 4f 73 86 15 81-c9 d6 d6 d6 c5 c5 0	

图 6.5: _MAX_HP 修改

用同样的方法再修改 _INITIAL_HP（图中已改完）：

PE ▾	Hex ▾	
004dfde0	ff 00 09 01 02 00 01 7f-00 00 00 00 00 00 00 00-ff 00 09 01 02	
004dfe00	ff ff 01 02 00 00 00 00-ff ff 01 02 00 00 ff ff-01 02 00 00 ff	
004dfe20	ff 00 09 01 02 00 03 7f-00 00 7d 00 00 00 00 00-ff ff 01 02 00	
004dfe40	01 02 00 00 ff ff 01 02-00 00 ff ff 01 02 00 00-ff ff 01 02 00	
004dfe60	00 00 ff ff 01 02 00 00-ff ff 01 02 00 00 ff ff-01 02 00 00 ff	
004dfe80	00 00 00 00 ff 00 09 01-02 00 01 7f 00 00 00 00-00 00 00 00 ff	
004dfea0	7d 00 00 00 00 00 00 00-dc 7c 4f 00 ff ff 01 00	
004e0000	0a 00 00 00 08 90 f6 1a-e3 0e 23 46 af 07 84 59-89 3e f0 59 0b	
004e0020	3e bb f6 7c 08 fd 07 a6-67 92 a1 39 cd 0d 28 ea-95 0c e0 aa e5	
004e0040	43 55 5d 60 04 00 00 00-da 0f 49 40 00 00 80 7f-00 00 20 41 00	
004e0060	00 00 40 42 9c ff ff ff-00 00 00 41 00 50 43 49-00 00 80 7f 00	
004e0080	04 00 00 00 04 00 00 00-02 00 00 00 00 01 00 00-00 00 00 80 00	
004e00a0	ff d8 ff e0 00 10 4a 46-49 46 00 01 01 01 00 60-00 60 00 00 ff	
004e00c0	00 2a 00 00 00 08 00 05-51 00 00 04 00 00 00 01-00 00 00 00 51	
004e00e0	51 02 00 01 00 00 03 00-00 00 00 4a 51 03 00 01-00 00 00 01 ff	

图 6.6: _INITIAL_HP 修改

再运行 game.exe，可以成功得到无限血量的下程实践。

6.1.2 子弹数量

同样，我们考虑把子弹也变成无限的，这样就可以无限使用高伤害技能。于是切换到 Hex edito 修改两个 bullet 的数值。

Symbols	Q	init	PE	Hex
Name	Address	Section		
pre_c_init	0x000401010	.te>	004064c0	ff 89 c1 e8 28 cc 0b 00 eb 7f 89 95 90 fb ff ff ff 8d 85 d0 fb ff ff c7 85 98
pre_cpp_init	0x000401130	.te>	004064e0	89 c1 e8 c5 5d 07 00 0b 85 90 fb ff ff 89 85 90 fb ff ff eb 25 8d 6d 18 8b
dia_init()	0x000403fdb	.te>	00406500	98 fb ff ff 85 c0 74 0c 83 e8 01 85 c0 74 bb 83 e8 01 0f 0b 89 95 90 fb ff
logic_init()	0x000405cd1	.te>	00406520	c7 85 98 fb ff ff 00 00 00 89 c1 e8 bf cb 0b 00 8b 85 90 fb ff ff 89 04
data_init()	0x00040655f	.te>	00406540	ff ff ff ff e8 87 19 06 00 8d 85 94 fb ff ff 89 04 24 e8 69 14 06 00 8d 65
resource_init...	0x00040a1a6	.te>	00406560	89 e5 83 ec 18 a1 70 00 4e 00 a3 e8 db 4f 00 c7 05 f0 db 4f 00 14 00 00 00
__static_init...	0x00040c012	.te>	00406580	e8 0a e9 ff ff c7 44 24 08 14 00 00 00 c7 44 24 04 00 00 00 c7 04 24 10
(static_initi...	0x00040f778	.te>	004065a0	00 c6 05 13 de 4f 00 01 0f b6 05 13 de 4f 00 a2 12 de 4f 00 0f b6 05 12 de
egge::graph_in...	0x0004137c0	.te>	004065c0	c7 05 c4 dd 4f 00 02 00 00 00 c7 05 c8 dd 4f 00 01 00 00 00 c7 05 cc dd 4f
egge::init_img...	0x0004142e0	.te>	004065e0	d0 dd 4f 00 04 00 00 00 c7 05 84 00 4e 00 04 00 00 00 a1 a8 bb 4e 00 a3 44
egge::initgrap...	0x0004143a0	.te>	00406600	00 a3 48 dc 4f 00 a1 48 bc 4e 00 a3 4c dc 4f 00 a1 b4 bb 4e 00 a3 50 dc 4f
egge::initgrap...	0x0004148a0	.te>	00406620	c4 dc 4f 00 c7 05 44 dd 4f 00 01 00 00 00 c7 05 f0 db 4f 00 14 00 00 00 c7
egge::setinitm...	0x0004149c0	.te>	00406640	00 00 c7 05 c4 dd 4f 00 05 00 00 00 c7 05 50 dd 4f 00 0a 00 00 c7 04 24
egge::IMAGE::i...	0x000422e40	.te>	00406660	ff ff e8 6a f6 ff ff c9 c3 55 89 e5 83 ec 38 d9 45 08 d9 ee d9 c9 df e9 dd
egge::egeContr...	0x00042e6a0	.te>	00406680	84 c0 75 47 d9 45 0c d9 ee d9 c9 df e9 dd d8 0f 93 c0 83 f0 01 84 c0 75 32
egge::egeContr...	0x00042e6b0	.te>	004066a0	45 08 d9 c9 df e9 dd d8 0f 93 c0 83 f0 01 84 c0 75 19 d9 05 dc db 4f 00 d9
egge::egeContr...	0x00042e6e0	.te>	004066c0	d8 0f 93 c0 83 f0 01 84 c0 74 07 b8 00 00 00 eb 49 8b d8 68 db 4f 00 8b
egge::egeContr...	0x000432770	.te>	004066e0	2c 55 e4 8b 45 08 89 45 e4 f3 0f 2c 45 e4 89 4c 24 08 89 54 24 04 89 04 24
_png_info_ini...	0x000433740	.te>	00406700	24 e8 0a 6b 02 00 89 45 f4 83 7d f4 00 75 07 b8 00 00 00 eb 05 b8 01 00
_png_init_rea...	0x00043a1f0	.te>	00406720	83 ec 18 8b 45 0c 89 44 24 04 8b 45 08 89 04 24 e8 34 ff ff ff 84 c0 74 57
_png_init_fll...	0x00043fd70	.te>	00406740	45 0c 89 44 24 04 d9 1c 24 e8 1b ff ff ff 84 c0 74 3e d9 45 0c d8 45 14 d9
_deflateInit2...	0x000447920	.te>	00406760	04 24 e8 02 ff ff ff 84 c0 74 25 d9 45 0c d8 45 14 d9 45 08 d8 45 10 d9 c9
_deflateInit...	0x000447c20	.te>	00406780	e8 4e fe ff ff 84 c0 74 07 b8 01 00 00 00 eb 05 b8 00 00 00 c9 c3 55 89
_inflateInit2...	0x000448310	.te>	004067a0	d9 00 d8 45 1c d9 05 40 0b 4e 00 de e9 8b 45 08 d9 00 d8 45 10 d9 c9 a1 40
_inflateInit...	0x0004484e0	.te>	004067c0	8b 45 18 89 44 24 08 d9 5c 24 04 d9 1c 24 e8 4a ff ff ff 84 c0 74 0d 8b 45
			004067e0	45 08 d9 18 8b 45 0c d9 00 d8 45 1c d9 05 40 bb 4e 00 de e9 d8 45 14 8b 45
			00406800	4e 00 89 54 24 0c 8b 55 18 89 54 24 08 d9 5c 24 04 89 04 24 e8 04 ff ff ff

图 6.7: bullet 修改

再运行 game.exe，可以成功得到无限子弹的卡程实践。但是同时发现整个程序在电脑上出现了严重的卡顿，故放弃这种改法。

不过，可以尝试增加消灭 monster 后获得的子弹奖励数，使卡程实践获得更多的子弹。

6.2 思路二：修改反汇编指令

鉴于我的游戏水平，在无限血量的加成之下最多也只进行到了第二关。所以这里考虑修改通关条件，每关不需要消灭一定数量的 monster 也可以进行到下一关。

这里找到 mainloop 函数，把 00406fdd 的 if (var_1e_1 == 1) 设置为 always Patch 无条件跳转：

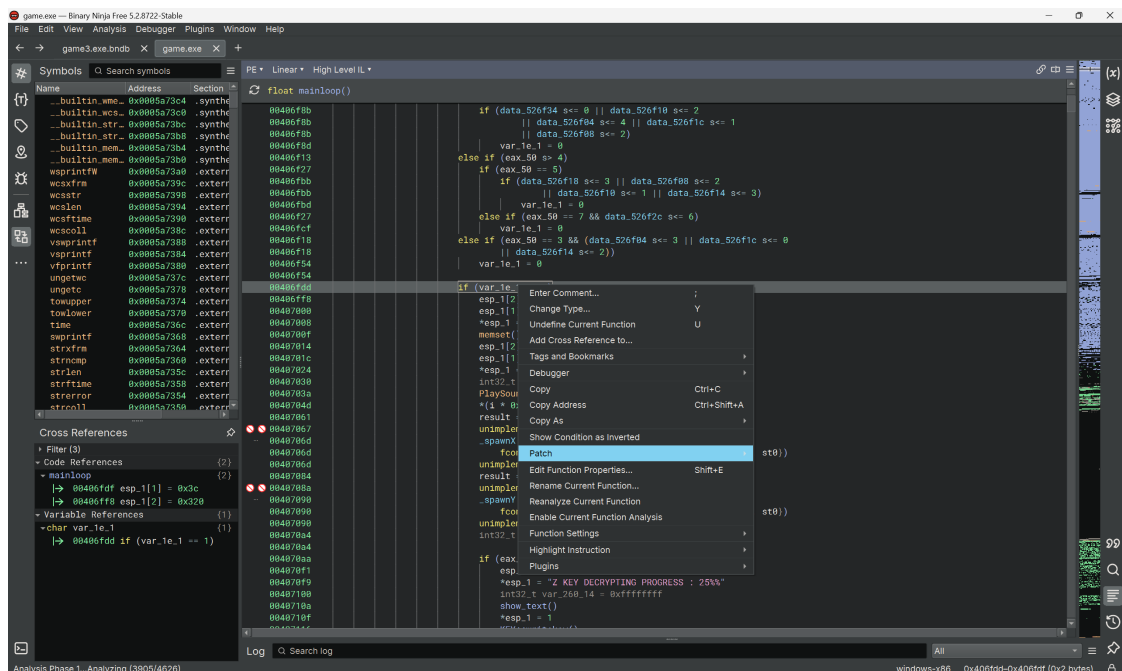


图 6.8: 修改点

最终得到：

```

1 004070aa if (eax_79 == 3) ; 如果eax寄存器值等于3
2 004070f1 bool var_2a8_9 = true ; 设置布尔变量为true
3 004070f9 var_2ac = "Z KEY DECRYPTING PROGRESS : 25%" ; 设置提示文本 (25%进度)
4 00407100 int32_t var_260_14 = 0xffffffff ; 设置值为-1 (可能是颜色或标志)
5 0040710a show_text(var_2ac, var_2a8_9) ; 显示文本 (参数: 文本内容和显示标志)
6 0040710f var_2ac = 1 ; 设置var_2ac值为1
7 00407116 KEY::writekey(var_2ac) ; 调用KEY类的writekey方法, 参数为1
8
9 004070aa else ; 否则 (eax_79 != 3)
10 004070be if (eax_79 == 4) ; 如果eax寄存器值等于4
11 0040711d bool var_2a8_10 = true ; 设置布尔变量为true
12 00407125 var_2ac = "Z KEY DECRYPTING PROGRESS : 50%" ; 50%进度文本
13 0040712c int32_t var_260_15 = 0xffffffff ; 设置值为-1
14 00407136 show_text(var_2ac, var_2a8_10) ; 显示50%进度文本
15 0040713b var_2ac = 2 ; 设置var_2ac值为2
16 00407142 KEY::writekey(var_2ac) ; 调用writekey方法, 参数为2
17 004070be else if (eax_79 == 5) ; 否则如果eax寄存器值等于5
18 00407149 bool var_2a8_11 = true ; 设置布尔变量为true
19 00407151 var_2ac = "Z KEY DECRYPTING PROGRESS : 75%" ; 75%进度文本
20 00407158 int32_t var_260_16 = 0xffffffff ; 设置值为-1
21 00407162 show_text(var_2ac, var_2a8_11) ; 显示75%进度文本
22 00407167 var_2ac = 3 ; 设置var_2ac值为3
23 0040716e KEY::writekey(var_2ac) ; 调用writekey方法, 参数为3
24
25 004070b4 if (eax_79 == 2) ; 单独判断: 如果eax寄存器值等于2
26 004070ce bool var_2a8_8 = true ; 设置布尔变量为true
27 004070d6 var_2ac = "Z KEY DECRYPTING PROGRESS : 0%" ; 0%进度文本
28 004070dd int32_t var_260_13 = 0xffffffff ; 设置值为-1
29 004070e7 show_text(var_2ac, var_2a8_8) ; 显示0%进度文本
30 ; 注意: 这里没有调用writekey方法, 可能是初始状态
31
32 00407174 var_2ac = &_before_level ; 获取_before_level的地址 (可能是关卡前状态)
33 0040717b save(var_2ac) ; 调用保存函数
34 00407191 var_2ac = *(i * 0xa8 + 0x52e798) ; 计算数组元素地址: 基址0x52e798 +
索引i*0xa8
35 00407194 int32_t var_260_17 = 0xffffffff ; 设置值为-1
36 0040719e prepare_map(var_2ac) ; 准备地图数据
37 004071a3 ecx_2 = logic_init() ; 初始化游戏逻辑, 返回值赋给ecx_2寄存器

```

这样每关即使不打 monster 也可以通关。

7 实验结果



图 7.9: 取得 Flag 截图

最后通关游戏，得到了 `flag{a2fdkd80xo}`

8 其他可能实现方式

通过对文件的分析思考，个人认为可能还有几种或许可行的但自己还未实践的思路：

1. 提前调用函数完成 key 的进程，之后直接跳转到 map6，得到 flag。
2. 编写代码，在本地依据给出的 writekey 和 btea 函数等等解出 key。

9 实验总结

本次实验使用 Binary Ninja 工具对可执行文件 game.exe 进行了静态分析、逻辑分析与二进制修改，最终成功获取游戏隐藏的 Flag。我学会了两种典型的二进制修改方法：直接修改数据段中的静态数值，以及修改条件跳转指令以实现逻辑绕过。同时，理解了从程序入口、主循环到具体函数调用的分析路径，学会通过关键字串、函数名与数据引用定位程序逻辑节点，建立对程序行为的整体认识。

逆向工程是一项融合了分析思维、技术工具与创造力的综合性工程。本次实验大大提高了我对逆向工程和 CTF 竞赛的兴趣。